BÁO CÁO CHI TIẾT DANH SÁCH LỖI (BUG REPORT)

TÍNH NĂNG FR-04: QUẢN LÝ HỒ SƠ CÁ NHÂN (POOL A)

- **Mã sinh viên:** 23120127
- **Họ và tên:** Dương Trọng Hòa
- **Hệ thống được kiểm thử (SUT):** EShop Platform (`http://localhost:5173` / Backend API `http://localhost:3000`)
- **Tổng số lỗi phát hiện:** 5 lỗi (1 Critical, 2 High, 2 Medium)
- **Ngày lập báo cáo:** 2026-10-18

DANH SÁCH CHI TIẾT CÁC LỖI ĐÃ PHÁT HIỆN

🦎 BUG #1: BUG-FR04-01 (High - Validation Logic Sai Lệch)

- **Tiêu đề Issue:** `[FR-04][BUG] Hệ thống từ chối số điện thoại 10 và 11 chữ số hợp lệ và thông báo sai lệch 9-10 chữ số`
- **Nhãn (Labels):** `bug`, `high`, `FR-04`, `validation`
- **Mức độ nghiêm trọng (Severity):** High
- **Mức độ ưu tiên (Priority):** High
- **Môi trường:** Chrome 120 / Windows 11 / EShop Local (Frontend: React, Backend: Node.js)

1. Mô tả lỗi

Theo đặc tả nghiệp vụ FR-04: "*Số điện thoại hợp lệ: bắt đầu bằng số 0, từ 10–11 chữ số*". Tuy nhiên, khi người dùng nhập số điện thoại 10 chữ số (`0912345678`) hoặc 11 chữ số (`01234567890`), hệ thống từ chối lưu và đưa ra thông báo lỗi mâu thuẫn: "*Số điện thoại không hợp lệ. Vui lòng nhập 9-10 chữ số*". Điều này khiến người dùng hợp lệ không thể cập nhật được số điện thoại chuẩn của Việt Nam.

2. Các bước tái hiện (Steps to Reproduce)

1. Đăng nhập vào hệ thống với tài khoản `test@eshop.com` / `Test1234!`.
2. Điều hướng tới trang **Hồ sơ cá nhân** (`http://localhost:5173/profile`).
3. Nhập Họ Tên: `"Nguyễn Văn A"`, Địa chỉ: `"123 Lê Lợi, Q1"`.
4. Nhập Số điện thoại 10 số hợp lệ: `"0912345678"`.
5. Nhấn nút **Cập nhật**.

3. Kết quả mong đợi (Expected Result)

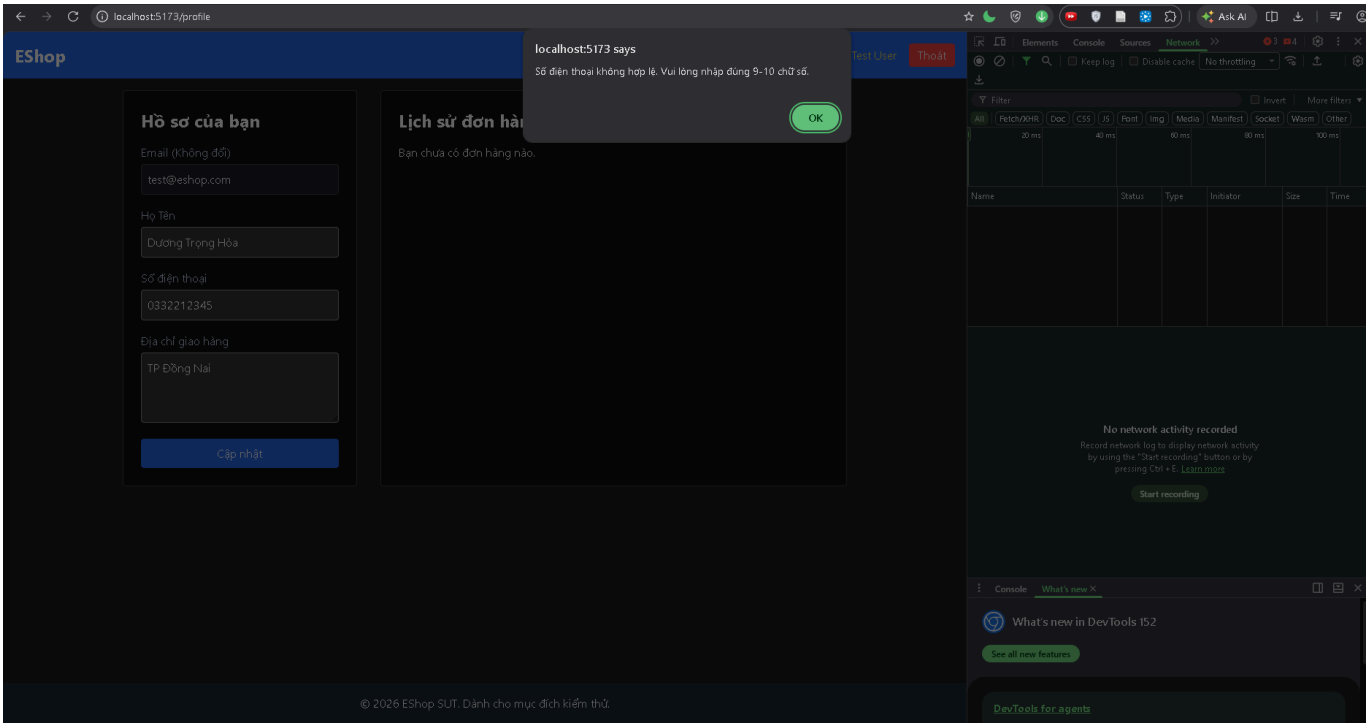
Hệ thống chấp nhận SĐT 10 số (và 11 số), cập nhật thành công vào CSDL SQLite và hiển thị thông báo thành công.

4. Kết quả thực tế (Actual Result)

Hệ thống báo lỗi: "*Số điện thoại không hợp lệ. Vui lòng nhập 9-10 chữ số*". Không cho phép lưu.

5. Bằng chứng hình ảnh (Screenshot)

- **Ảnh minh chứng:** `EXE-02_Valid_10Digits_Phone.png`



🐛 BUG #2: BUG-FR04-02 (Medium - Data Integrity)

- **Tiêu đề Issue:** `[FR-04][BUG] Hệ thống cho phép cập nhật và lưu Địa chỉ giao hàng rỗng vào CSDL`
- **Nhãn (Labels):** `bug`, `medium`, `FR-04`, `data-integrity`
- **Mức độ nghiêm trọng (Severity):** Medium
- **Mức độ ưu tiên (Priority):** Medium
- **Môi trường:** Chrome 120 / Windows 11 / EShop Local (Frontend: React, Backend: Node.js)

1. Mô tả lỗi

Trường "Địa chỉ giao hàng mặc định" là thông tin thiết yếu để phục vụ chức năng Thanh toán & Giao hàng (FR-08, FR-18). Tuy nhiên, form cập nhật hồ sơ và Backend API cho phép người dùng xóa trắng địa chỉ và bấm lưu thành công, ghi đè chuỗi rỗng `""` vào CSDL SQLite.

2. Các bước tái hiện (Steps to Reproduce)

1. Truy cập vào trang Hồ sơ cá nhân (`http://localhost:5173/profile`).
2. Nhập Họ Tên: `"Nguyễn Văn A"`, SĐT hợp lệ.
3. Xóa sạch ô **Địa chỉ giao hàng mặc định** (để rỗng 0 ký tự).
4. Nhấn nút **Cập nhật**.

3. Kết quả mong đợi (Expected Result)

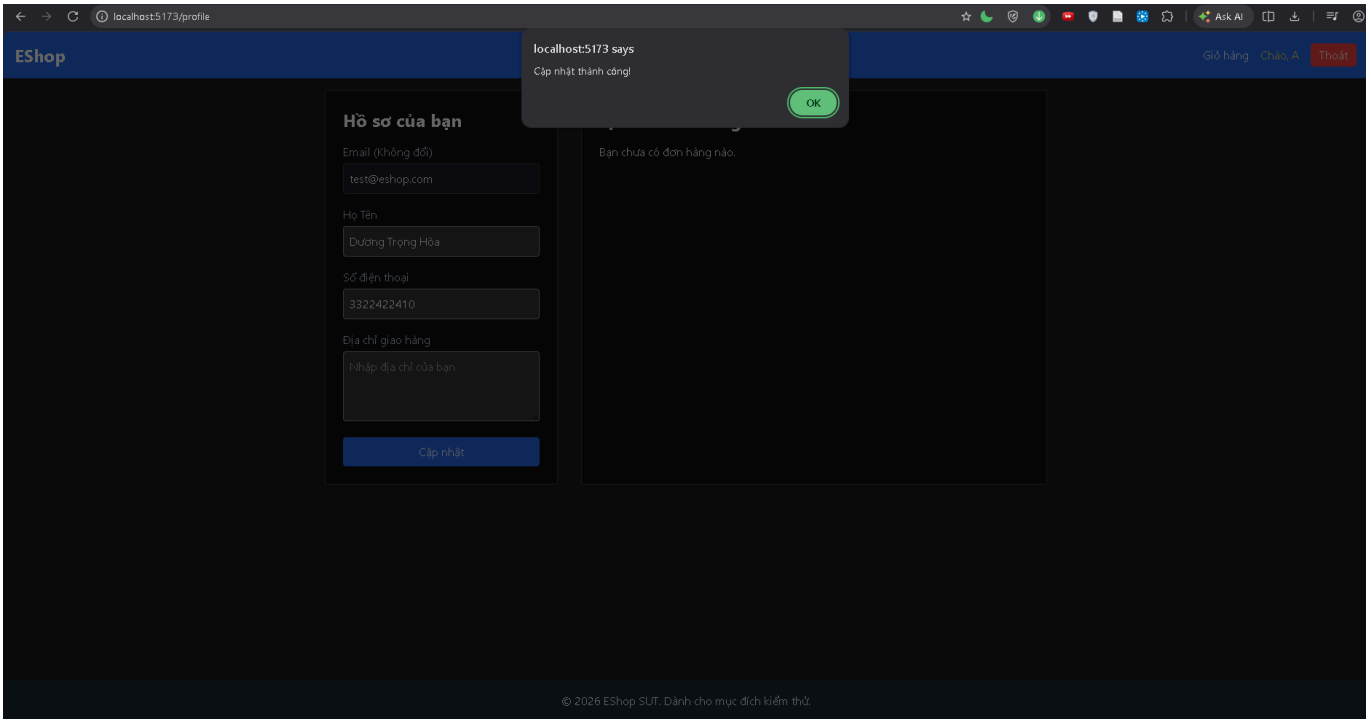
Hệ thống phải chặn lại, hiển thị thông báo lỗi yêu cầu nhập địa chỉ ở phía trên nút bấm (theo FR-22).

4. Kết quả thực tế (Actual Result)

Hệ thống hiển thị thông báo "Cập nhật thành công" và CSDL lưu địa chỉ rỗng.

5. Bằng chứng hình ảnh (Screenshot)

- **Ảnh minh chứng:** `EXE-07_Error_Empty_Address.png`



🐛 BUG #3: BUG-FR04-03 (Medium - Boundary Validation)

- **Tiêu đề Issue:** `[FR-04][BUG] Không giới hạn độ dài tối đa 255 ký tự cho trường Họ Tên và Địa chỉ`
- **Nhãn (Labels):** `bug`, `medium`, `FR-04`, `boundary`
- **Mức độ nghiêm trọng (Severity):** Medium
- **Mức độ ưu tiên (Priority):** Low/Medium
- **Môi trường:** Chrome 120 / Windows 11 / EShop Local (Frontend: React, Backend: Node.js)

1. Mô tả lỗi

Tại ranh giới kiểm thử Max + 1 (256 ký tự), cả giao diện Frontend và API Backend đều không có cơ chế chặn giới hạn độ dài (thiếu thuộc tính `maxlength="255"` trên thẻ `<input>`), cho phép lưu chuỗi dài tùy ý vào CSDL SQLite.

2. Các bước tái hiện (Steps to Reproduce)

1. Mở Console trong F12 gõ: `copy('A'.repeat(256))` để lấy chuỗi 256 ký tự.
2. Dán chuỗi này vào ô **Họ Tên** và **Địa chỉ**.
3. Nhấn nút **Cập nhật**.

3. Kết quả mong đợi (Expected Result)

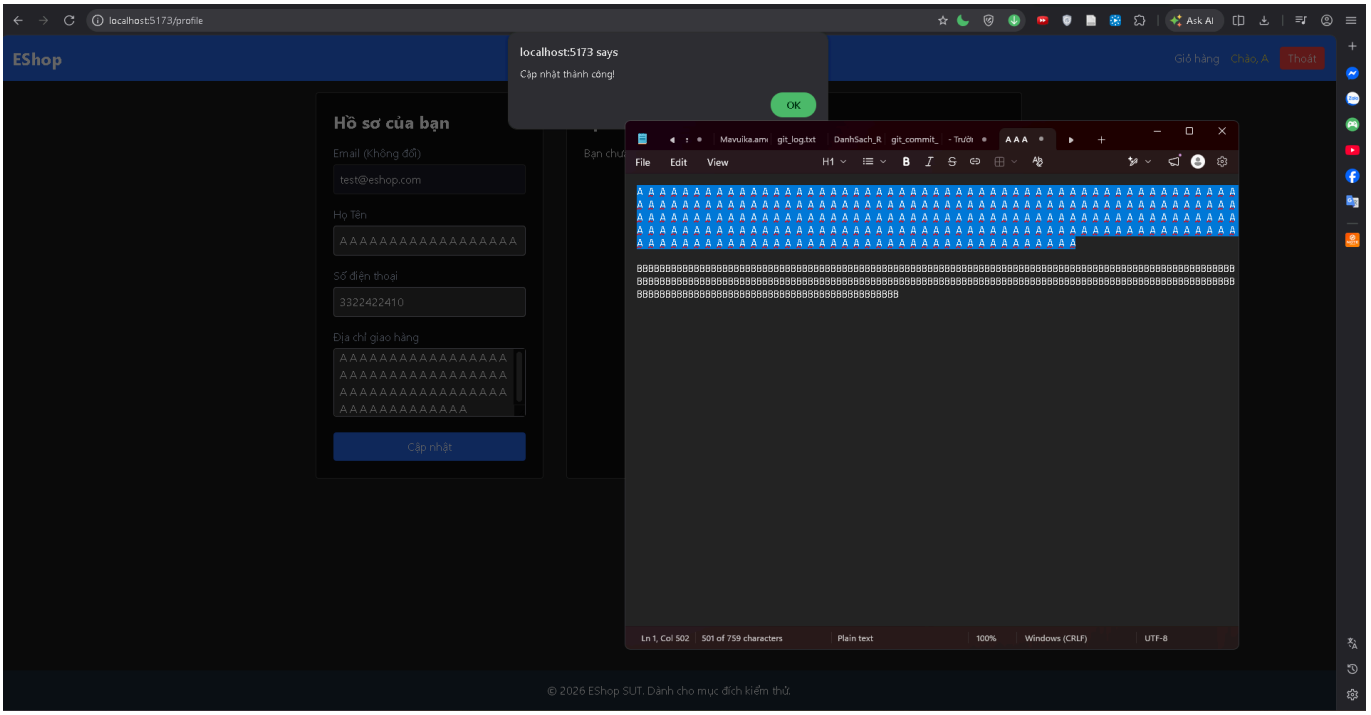
Hệ thống chặn không cho nhập ký tự thứ 256 hoặc Backend trả về mã lỗi HTTP 400 Bad Request từ chối chuỗi quá dài.

4. Kết quả thực tế (Actual Result)

Hệ thống chấp nhận và lưu chuỗi 256 ký tự thành công.

5. Bằng chứng hình ảnh (Screenshot)

- **Ảnh minh chứng:** `EXE-08_BVA_MaxPlus1_256Chars.png`



🐛 BUG #4: BUG-FR04-04 (High - Boundary Validation)

- **Tiêu đề Issue:** `[FR-04][BUG] Hệ thống chấp nhận số điện thoại không bắt đầu bằng số 0`
- **Nhãn (Labels):** `bug`, `high`, `FR-04`, `boundary`
- **Mức độ nghiêm trọng (Severity):** High
- **Mức độ ưu tiên (Priority):** High
- **Môi trường:** Chrome 120 / Windows 11 / EShop Local (Frontend: React, Backend: Node.js)

1. Mô tả lỗi

Đặc tả FR-04 quy định rõ ràng: "*Số điện thoại hợp lệ: bắt đầu bằng số 0*". Tuy nhiên, hệ thống cho phép người dùng nhập số điện thoại bắt đầu bằng chữ số khác 0 (ví dụ: `1912345678`) và lưu thành công vào CSDL.

2. Các bước tái hiện (Steps to Reproduce)

1. Tại trang Hồ sơ cá nhân, nhập Họ Tên và Địa chỉ hợp lệ.
2. Nhập Số điện thoại: `"1912345678"` (bắt đầu bằng số 1 thay vì số 0).
3. Nhấn nút **Cập nhật**.

3. Kết quả mong đợi (Expected Result)

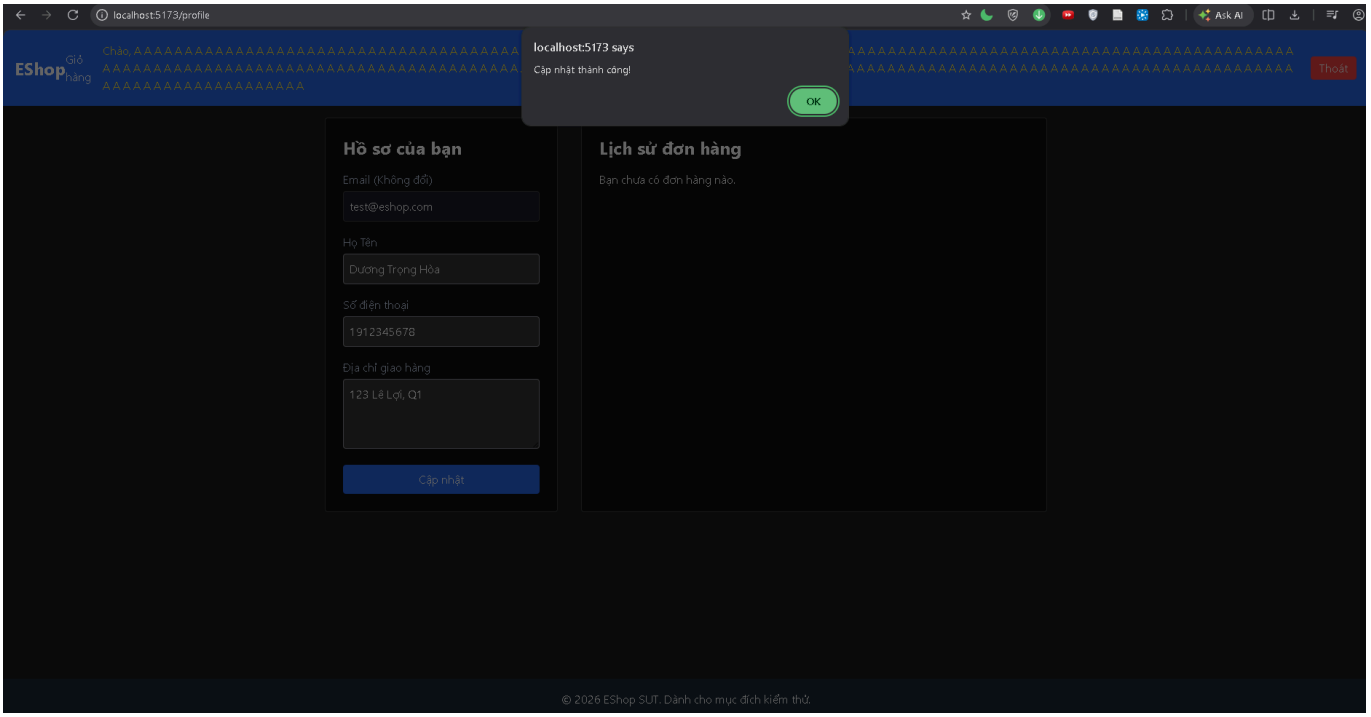
Hệ thống từ chối cập nhật, hiển thị lỗi yêu cầu số điện thoại phải bắt đầu bằng số 0.

4. Kết quả thực tế (Actual Result)

Hệ thống báo cập nhật thành công và lưu số điện thoại sai định dạng vào CSDL.

5. Bằng chứng hình ảnh (Screenshot)

- **Ảnh minh chứng:** `EXE-12_BVA_Phone_NotStartWithZero.png`



🚨 BUG #5: BUG-FR04-05 (CRITICAL - SECURITY VULNERABILITY)

- **Tiêu đề Issue:** `[FR-04][SEC-06][CRITICAL] Lỗ hổng Leo thang đặc quyền (Privilege Escalation) cho phép User tự đổi role="admin"`
- **Nhãn (Labels):** `bug`, `critical`, `security`, `FR-04`, `SEC-06`
- **Mức độ nghiêm trọng (Severity):** Critical (Nghiêm trọng nhất)
- **Mức độ ưu tiên (Priority):** Urgent / Immediate
- **Môi trường:** Chrome 120 / Windows 11 / EShop Local (Frontend: React, Backend: Node.js)

1. Mô tả lỗi

Đặc tả FR-04 và SEC-06 nghiêm cấm: "*Người dùng chỉ có thể cập nhật hồ sơ của chính mình; không thể tự thay đổi thuộc tính role*". Tuy nhiên, trong mã nguồn Backend tại `backend/server.js` (dòng 124-127):

2. Các bước tái hiện (Steps to Reproduce)

3. Kết quả mong đợi (Expected Result)

4. Kết quả thực tế (Actual Result)

5. Bằng chứng hình ảnh (Screenshot)

- **Ảnh minh chứng:** `EXE-15_Bug_Privilege_Escalation.png`

